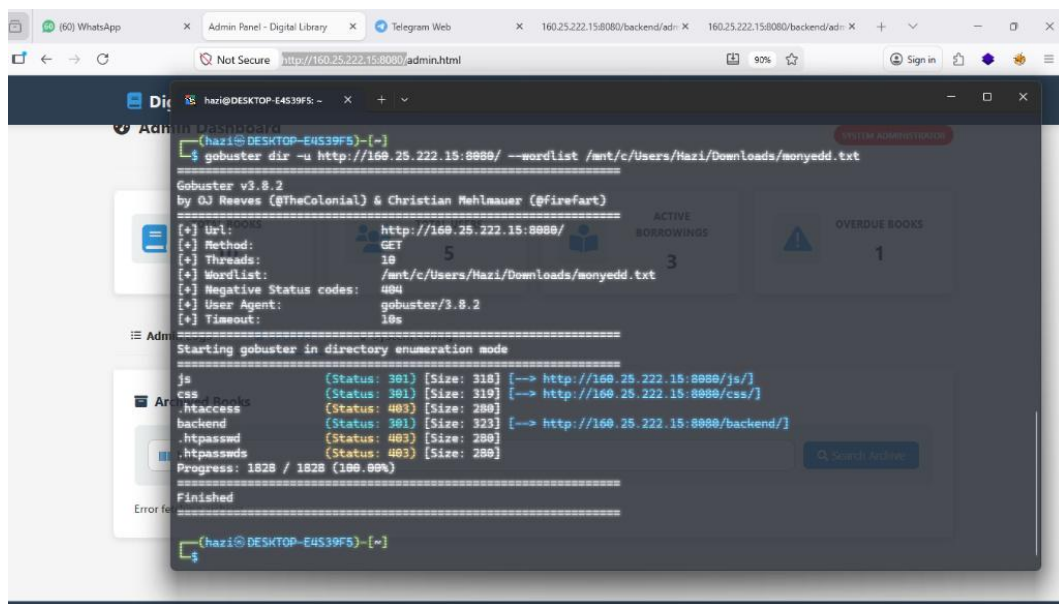


POC FLAG 6 : File apa yang dapat kamu include melalui parameter debug?

1. Tahap Awal: Enumerasi Direktori dengan Gobuster

Proses pencarian flag dimulai dengan melakukan pemindaian (*scanning*) pada URL target `http://160.25.222.15:8080/`. Langkah ini bertujuan untuk mengidentifikasi apakah terdapat direktori tersembunyi yang dapat diakses di dalam server tersebut. Untuk tugas ini, saya menggunakan alat bantu **Gobuster v3.8.2** dengan metode *directory mode* dan bantuan *wordlist* kustom.

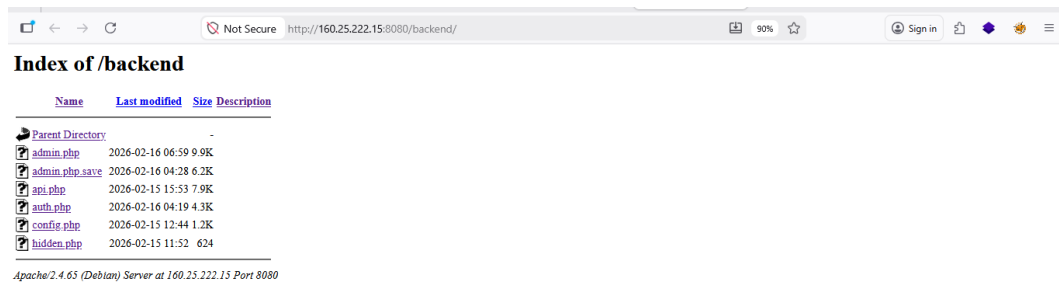


```
haz@DESKTOP-E4S39FS:~$ gobuster dir -u http://160.25.222.15:8080/ --wordlist /mnt/c/Users/Hazi/Downloads/monyedd.txt
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[*] Url: http://160.25.222.15:8080/
[*] Method: GET
[*] Threads: 10
[*] Wordlist: /mnt/c/Users/Hazi/Downloads/monyedd.txt
[*] Negative Status codes: 404
[*] User Agent: gobuster/3.8.2
[*] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
js (Status: 301) [Size: 318] [==> http://160.25.222.15:8080/js/]
css (Status: 301) [Size: 319] [==> http://160.25.222.15:8080/css/]
htaccess (Status: 403) [Size: 280]
backend (Status: 301) [Size: 323] [==> http://160.25.222.15:8080/backend/]
htpasswd (Status: 403) [Size: 280]
Progress: 1828 / 1828 (100.00%)
=====
Finished
=====
haz@DESKTOP-E4S39FS:~$
```

Berdasarkan hasil pemindaian yang dilakukan, sistem menunjukkan keberadaan beberapa direktori aktif yang cukup mencolok, di antaranya adalah **/backend**, **/css**, dan **/js**.

2. Identifikasi Kerentanan pada Direktori **/backend**

Melihat hasil pemindaian tersebut, kecurigaan saya langsung tertuju pada direktori **/backend**. Secara struktur aplikasi web, direktori *backend* umumnya menyimpan logika pemrosesan data atau file konfigurasi yang bersifat sensitif. Saat saya mencoba mengakses `http://160.25.222.15:8080/backend/` melalui browser, ditemukan bahwa fitur *Directory Listing* pada server tersebut aktif.



Name	Last modified	Size	Description
Parent Directory	-	-	-
admin.php	2026-02-16 06:59	9.9K	
admin.php.save	2026-02-16 04:28	6.2K	
api.php	2026-02-15 15:53	7.9K	
auth.php	2026-02-16 04:19	4.3K	
config.php	2026-02-15 12:44	1.2K	
hidden.php	2026-02-15 11:52	624	

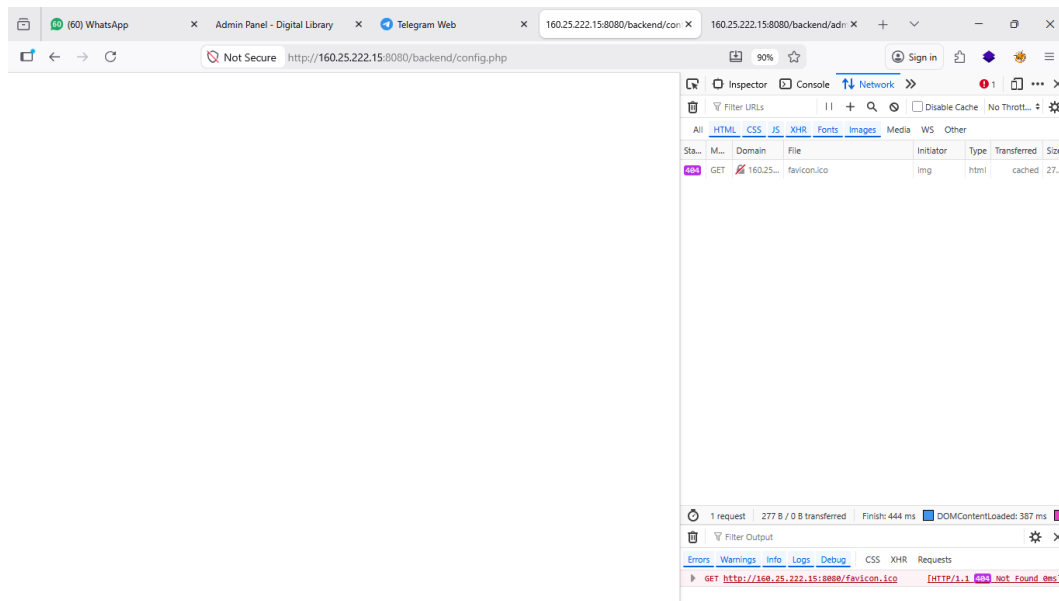
Apache/2.4.63 (Debian) Server at 160.25.222.15 Port 8080

Kondisi ini memungkinkan siapa pun untuk melihat daftar file yang ada di dalam direktori tersebut secara terbuka. Di sana terlihat beberapa file penting seperti `admin.php`, `admin.php.save`, `api.php`, `auth.php`, `config.php`, hingga `hidden.php`.

3. Analisis Respon Server

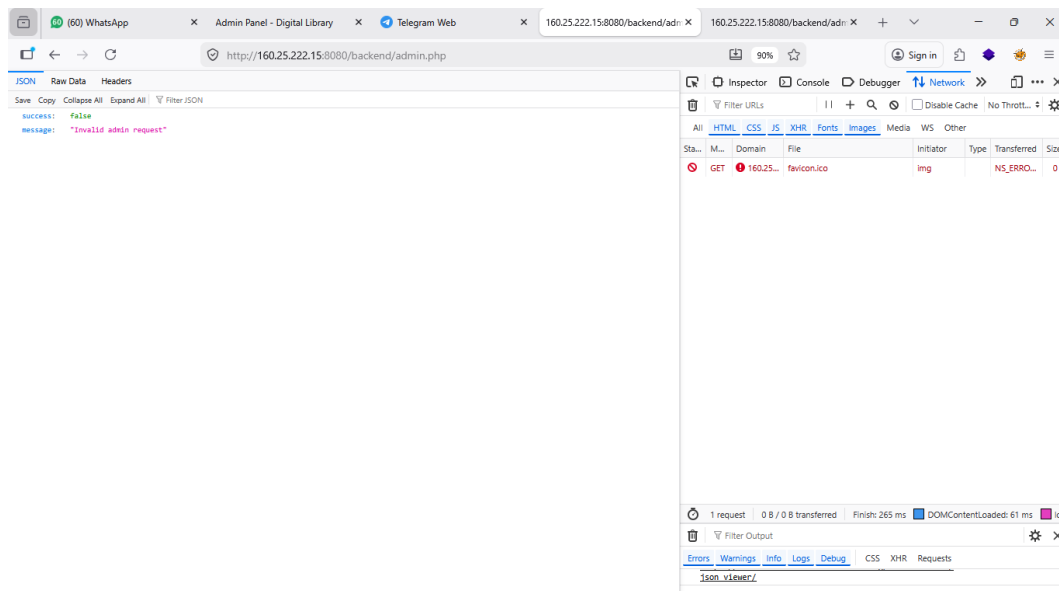
Sebelum menentukan target file, saya melakukan analisis terhadap respon server dengan mengakses file-file tersebut secara langsung melalui peramban sambil memantau *Network Tab*.

Pertama, saat mengakses `config.php`, server hanya menampilkan halaman kosong (*blank page*). Hal ini mengindikasikan bahwa file tersebut memang ada di server namun tidak memberikan *output* langsung ke layar.



Akses Direct config.php

Kedua, saat mencoba mengakses admin.php, server memberikan respon balik dalam format JSON: {"success": false, "message": "Invalid admin request"}. Respon ini sangat krusial karena membuktikan bahwa sistem *backend* sedang aktif melakukan validasi terhadap setiap permintaan yang masuk.



Respon JSON admin.php

4. Tahap Eksekusi: Verifikasi Nama File (Brute-Guess)

Berdasarkan data file yang telah terkumpul dari direktori `/backend` tersebut, saya melakukan analisis manual untuk menentukan file mana yang paling memungkinkan untuk flag. Dari daftar yang tersedia, saya mencurigai **config.php** karena secara standar pengembangan aplikasi PHP, file ini sering digunakan untuk menyimpan konfigurasi utama dan kredensial sensitif.

Saya kemudian melakukan verifikasi dengan memasukkan nama file tersebut sebagai jawaban (metode *brute-guess*) pada sistem tantangan atau bot yang tersedia.



Setelah mengirimkan input **config.php**, sistem memberikan konfirmasi bahwa jawaban tersebut **BENAR**. Dengan demikian, Flag 6 berhasil didapatkan melalui tahapan enumerasi direktori dan analisis file yang sistematis.